

The most common reason for fumbling is lookup failure which happens mainly due to misaddressing, the movement of the host or due to the non-existence of a resource. Other than this, an automated search of destination targets, and scanning of addresses and their ports are possible causes of fumbling. Sometimes, to search a target host, automated measures are taken to check whether the target is up and running. These types of failed attempts are generally mistaken for network attacks, though lookup failure happens either due to misconfiguration of DNS, a faulty redirection on the Web server, or email with a wrong URL. Similarly, SMTP communication uses an automated network traffic control scheme for its destination address search.

The most serious cause of fumbling is repeated scanning by attackers. Attackers scan the entire address-port combination matrix either in vertical or in horizontal directions. Generally, attackers explore horizontally, as they are most interested in exploring potential vulnerabilities. Vertical search is basically a defensive approach to identify an attack on an open port address. As an alternative to scanning, at times attackers use a hit-list to explore a vulnerable system. For example, to identify SSH host, attackers may use a blind scan and then start a password attack.

Identifying fumbling

Identifying malicious fumbling is not a trivial task, as it requires demarcating innocuous fumbling from the malevolent kind. Primarily, the task of assessing failed accesses to a resource is to identify whether the failure is consistent or transient. To explore TCP fumbling, look into all TCP communication flags, payload size and packet count. In TCP communication, the client sends an ACK flag only after receiving the SYN+ACK signal from the server. If there is no ACK after a SYN from the server, then that indicates a fumbling. Another possible way to locate a malicious attack is to count the number of packets of a flow. A legitimate TCP flow requires at least three packets of overhead before it considers transmitting data. Most retries require three to five packets, and TCP flows having five packets or less are likely to be fumbles.

Since, during a failed connection, the host sends the same SYN packets options repeatedly, a ration of packet size and packet number is also a good measure of identifying TCP flow fumbling.

ICMP informs a user about why a connection failed. It is also possible to look into the ICMP response traffic to identify fumbling. If there is a sudden spike in messages originating from a router, then there is a good chance that a target is probing the router's network. A proper forensic investigation can identify a possible attacking host attacking host.

Since UDP does not follow TCP as a strict communication protocol, the easiest way to identify UDP fumbling is by exploring network mapping and ICMP fumbling.

Identifying service level fumbling is comparatively

easier than communication level fumbling, as in most of the cases exhaustive logs record each access and malfunction. For example, HTTP returns three-digit status codes 4xx for every client-side error. Among the different codes, 404 and 401 are the most common for unavailability of resources and unauthorised access, respectively. Most of the 404 errors are innocuous, as they occur due to misconfiguration of the URL or the internal vulnerabilities of different services of the HTTP server. But if it is a 404 scanning, then it may be malicious traffic and there may be a chance that attackers are trying to guess the object in order to reach the vulnerable target. Web server authentication is really used by modern Web servers. In case of discovering any log entry of an 401 error, proper steps should be taken to remove the source from the server.

Another common service level vulnerability comes from the mail service protocol, SMTP. When a host sends a mail to a non-existent address, the server either rejects the mail or bounces it back to the source. Sometimes it also directs the mail to a catch-all account. In all these three cases, the routing SMTP server keeps a record of the mail delivery status. But the main hurdle of identifying SMTP fumbling comes from spam. It's hard to differentiate SMTP fumbling from spam as spammers send mail to every conceivable address. SMTP fumlbers also send mails to target addresses to verify whether an address exists for possible scouting out of the target.

Designing a fumbling identification system

From the above discussion, it is apparent that identifying fumbling is more subjective than objective. Designing a fumbling identification and alarm system requires in-depth knowledge of the network and its traffic pattern. There are several network tools, but here we will cover some basic system utilities so that readers can explore the infinite possibilities of designing network intrusion detection and prevention systems of their own.

In order to separate malicious from innocuous fumbling, the analyst should mark the targets to determine whether the attackers are reaching the goal and exploring the target. This step reduces the bulk of data to a manageable state and makes the task easier. After fixing the target, it is necessary to examine the traffic to study the failure pattern. If it is TCP fumbling, as mentioned earlier, this can be detected by finding traffic without the ACK flag. In case of an HTTP scanning, examination of the HTTP server log table for 404 or 401 is done to find out the malicious fumbling. Similarly, the SMTP server log helps us to find out doubtful emails to identify the attacking hosts.

If a scouting happens to a dark space of a network, then the chance of malicious attack is high. Similarly, if a scanner scans more than one port in a given time frame, the chance of intrusion is high. A malicious attack can be confirmed by examining the conversation between the attacker and the target. Suspicious conversations can be subsequent transfers